

ENDEUDADOS

Revisión Cruzada de Código sin PR

Sprint 2

1. Contexto y alcance

Al revisar el historial de la rama main con "git log main --first-parent --oneline", se encontró que de los commits que llegaron a main, solo dos corresponden a un Pull Request real (#10 y #11). El resto del proyecto —landing, autenticación, diseño compartido y la pantalla completa de Ingresos y Gastos— se subió directo a main sin revisión de otra persona del equipo.

Por esto, en vez de revisar commit por commit, esta auditoría evalúa el estado actual del código de las pantallas que nunca pasaron por PR, como si fuera una revisión de Pull Request hecha a posteriori.

Historial de commits en main

Commit	Descripción	¿Pasó por PR?
e37a99d	Merge pull request #11 (fix/registro-trigger)	Con PR
fcf90ad	Merge pull request #10 (feature/recuperar-contrasena)	Con PR
d3121d6	Registro y gastos con la base de datos	Sin PR
f2085ff	feat(ingresos-gastos): vista y capa de datos (EN-4, EN-5, EN-6)	Sin PR
74f8ebb	style: nueva distribución de secciones, hero y CTA	Sin PR
f4e4afd	docs(ingresos-gastos): notas sobre categorías y recarga	Sin PR
f5cd094	feat(ingresos-gastos): registro y resumen (EN-4, EN-5, EN-6)	Sin PR
f3ccfb4	style(landing): rediseño con secciones e iconos SVG	Sin PR
7ca28e0	style(auth): rediseño de login, registro y recuperación	Sin PR
b7923e1	style(diseño): sistema de diseño compartido	Sin PR
21b4c82	Descripción mejor para GitHub	Sin PR
25ea2e5 / 9861e57 / df31048	Lógica botón refrescar (3 commits)	Sin PR
1b29b6c	Mejora de lógica de cédula duplicada / registro simultáneo	Sin PR
71617ed	Merge branch "main" (sincronización local, no es PR)	Sin PR
478d262	Despliegue en Vercel y mejora de mensajes	Sin PR
8b79a10 / baa85e9 / 4e095b4 / 5acdc7a / 59894d6	Estructura inicial, archivo auth.js, v1, commit inicial	Sin PR

2. Metodología

- Se excluyeron de la revisión profunda los commits que ya tuvieron Pull Request (#10 recuperar contraseña, #11 fix del trigger de registro), ya que esos sí pasaron por ojos de otra persona.
- Se revisó el resto del código pantalla por pantalla: landing (index), autenticación (loRe, auth.js, recPass), Ingresos y Gastos (inGas, datos.js, calculos.js) y el sistema de diseño compartido (base.css).
- Para cada archivo se evaluó: seguridad (manejo de datos y sesión), manejo de errores, accesibilidad, consistencia con el resto del proyecto y comentarios desactualizados.

3. Hallazgos

Archivo	Severidad	Hallazgo	Recomendación
LoginRegistro/auth.js	Media	Crea su propio cliente de Supabase con URL y key repetidas, en vez de usar shared/supabase.js (ya anotado como pendiente, EN-29).	Migrar a sbClient compartido. Si la key cambia, hoy hay que actualizarla en dos archivos.
LoginRegistro/auth.js	Media	Al registrar, cualquier error con status ≥ 500 se interpreta como "cédula o correo ya registrados".	Loguear el código y mensaje real del error; no asumir la causa solo por el rango de status, podría ocultar una caída real del servidor.
auth.js y recPass.js	Baja	Los mensajes de error distinguen casos buscando palabras dentro de error.message (ej. .includes('confirm'), .includes('session')).	Es frágil ante cambios de texto en los errores de Supabase. Si existe, usar error.code o un código de estado en vez de texto libre.
IngresosGastos/datos.js	Media	Las consultas SELECT y DELETE (ingresos, gastos, hormiga, deudas) no filtran por usuario_id en el código: dependen por completo de RLS.	Confirmar y documentar que las políticas RLS de SELECT y DELETE exigen que la fila pertenezca al usuario autenticado, para no depender de un único punto de control.
IngresosGastos/inGas.js	Baja	El comentario de verificarSesion() dice que "getUsuarioActual() devuelve un usuario simulado", pero datos.js ya usa la sesión real de Supabase.	Actualizar el comentario para que no confunda a quien lea el código más adelante.
loRe.html y recPass.html	Baja	Los mensajes de error/éxito no tienen role="alert" ni aria-live, a diferencia de inGas.html que sí lo hace de forma consistente.	Agregar role="alert" (como ya existe en inGas.html) para que un lector de pantalla anuncie el resultado sin que el usuario deba buscarlo.
LoginRegistro/loRe.js	Baja	Al recargar (F5) la pantalla de login, siempre redirige a la landing, incluso si el usuario ya tiene sesión activa.	No es una pérdida de sesión real, solo una inconsistencia de navegación. Se podría redirigir directo a

Archivo	Severidad	Hallazgo	Recomendación
			inGas.html si ya hay sesión.
General (auth.js, recPass.js)	Positivo	Buena práctica ya presente: los mensajes nunca revelan si un correo o cédula ya existen en el sistema.	Mantenerlo así; evita que alguien use el formulario para averiguar quién está registrado.
General (calculos.js, base.css)	Positivo	Buena práctica ya presente: topes de seguridad en cálculos (monto máximo, 120 meses de simulación) y contraste de color documentado explícitamente.	Mantener el mismo estándar al agregar nuevas pantallas.

4. Conclusiones

El código funciona y, en general, sigue buenas prácticas: separa capas de datos y lógica, documenta sus decisiones de accesibilidad y diseño, y evita filtrar información sensible en los mensajes de error. Los hallazgos de esta auditoría son en su mayoría de severidad media o baja — nada bloqueante — y el más relevante (duplicación del cliente de Supabase en auth.js) ya estaba identificado por el propio equipo como pendiente (EN-29).

El riesgo real de no tener PRs no es que el código esté mal escrito, sino que estos hallazgos no se detectaron hasta ahora: nadie más que el autor había leído ese código antes de que quedara integrado. De aquí en adelante, el equipo acordó pasar por Pull Request todo cambio nuevo, para que este tipo de revisión ocurra antes del merge y no después.